

Desglose de un Incidente Complejo

Actividad Práctica AP 08

Seguridad de la Información y Ciberseguridad

Alumno: Xavier Margalef Riestra

Actividad: AP 08 - Desglosar un incidente complejo

Fecha de entrega: 14 de Julio de 2026

Informe Técnico

Índice

1. Reacción Inmediata	2
1.1. ¿Qué tipo de auditoría debe ejecutarse en este mismo momento y por qué? .	2
2. Análisis	2
2.1. Paso 1: XSS en portal web obsoleto → robo de sesión	3
2.2. Paso 2: Red sin segmentación → acceso desde soporte a bases de datos de tarjetas	3
2.3. Paso 3: Credenciales en texto plano	3
2.4. Gestión de Proyectos IT (fallo estructural)	4
3. Normativa	4
3.1. ¿Qué auditoría específica acaba de reprobar estrepitosamente la empresa en el paso 4, enfrentándose a multas millonarias?	4
4. Reacciones	5
4.1. Respuesta al Director General (CEO)	5

1. Reacción Inmediata

1.1. ¿Qué tipo de auditoría debe ejecutarse en este mismo momento y por qué?

Respuesta a Incidentes dentro de Seguridad de la Información y Ciberseguridad

Habría que realizar un **DFIR (Digital Forensics and Incident Response)**, ya que entra en acción después de que se ha producido un incidente o ciberataque. En esta ocasión el ataque ya ha sido perpetrado y ha generado consecuencias, por lo que debemos identificar y recopilar información sobre lo ocurrido y determinar cómo reaccionar.

Objetivos principales del DFIR:

- Identificar el origen del ataque.
- Reconstruir la cadena de eventos (*timeline*).
- Preservar evidencias digitales (logs, memoria y discos).
- Establecer el alcance real de la exfiltración de datos.

En este caso concreto, el **DFIR** es crítico porque existe:

- Fuga masiva de datos.
- Impacto legal derivado de la investigación gubernamental.
- Riesgo de pérdida de licencias de Visa y Mastercard.

CAATs utilizados en esta fase

- **ELK Stack / Splunk** → análisis de grandes volúmenes de logs.
- **Wireshark** → análisis de tráfico de red sospechoso.
- **Autopsy** → análisis forense de discos.
- **Snort / OSSEC** → detección de intrusiones previas.

2. Análisis

Si GlobalPay hubiera hecho bien su trabajo antes del ataque, ¿qué tres tipos específicos de auditorías preventivas habrían detectado y evitado los pasos 1, 2 y 3 del atacante? Relaciona cada auditoría con su paso correspondiente.

Aquí aplicamos conceptos de Gestión de Proyectos IT, SDLC, Seguridad de la Información y Ciberseguridad.

2.1. Paso 1: XSS en portal web obsoleto → robo de sesión

Se utilizaría una auditoría de **Aplicaciones y Desarrollo (SDLC)** mediante análisis web enfocado en **Seguridad en Aplicaciones y APIs (OWASP)**.

Habría detectado:

- Vulnerabilidades OWASP Top 10 (XSS).
- Falta de validación de entradas.
- Ausencia de pruebas de seguridad dentro del ciclo de vida del software.

Herramientas típicas:

- OWASP ZAP.
- Burp Suite.
- Pruebas basadas en OWASP Top 10.

2.2. Paso 2: Red sin segmentación → acceso desde soporte a bases de datos de tarjetas

Se utilizaría una auditoría de **Seguridad de la Información y Ciberseguridad** centrada en **Network Security Assessment**.

Habría detectado:

- Falta de segmentación mediante VLAN.
- Ausencia de arquitectura Zero Trust.
- Movimiento lateral libre entre redes críticas.

CAATs utilizados:

- Nmap → mapeo de red.
- Snort / IDS-IPS → detección de intrusiones.
- MITRE ATT&CK → modelado de técnicas de ataque.

2.3. Paso 3: Credenciales en texto plano

Escenario: Script de backup con contraseña de administrador expuesta.

Se utilizaría una auditoría de **Aplicaciones y Desarrollo (SDLC)** mediante **Análisis de Código (DevSecOps / Software Security)**.

Habría detectado:

- Credenciales hardcodeadas.

- Malas prácticas de programación.
- Ausencia de revisiones de código.

CAATs utilizados:

- SAST (Static Application Security Testing).
- Análisis de repositorios de código.
- Scripts de auditoría en Python y SQL.

2.4. Gestión de Proyectos IT (fallo estructural)

Este problema constituye la causa raíz organizativa y no forma parte directamente del patrón de ataque.

Problema detectado:

Portal sin actualizar durante dos años.

Auditoría aplicable:

Gestión de Proyectos IT.

Habría detectado:

- Falta de mantenimiento del software.
- Mala planificación de actualizaciones.
- Ausencia de controles de calidad en las entregas.

Resultado:

El sistema no habría quedado obsoleto y la superficie de ataque se habría reducido significativamente.

3. Normativa

3.1. ¿Qué auditoría específica acaba de reprobar estrepitosamente la empresa en el paso 4, enfrentándose a multas millonarias?

Auditoría fallida: Auditoría de Cumplimiento Normativo (Compliance)

Normativas incumplidas:

- PCI-DSS.
- RGPD / LOPDGDD.

- ISO 27001.

Consecuencias:

- Multas económicas elevadas.
- Investigación gubernamental.
- Pérdida de licencias para el procesamiento de pagos.

4. Reacciones

4.1. Respuesta al Director General (CEO)

El CEO propone contratar urgentemente una Auditoría de Seguridad Física para evitar que el incidente vuelva a ocurrir.

Como Auditor Jefe, respondería que la auditoría de seguridad física no es prioritaria en este caso, ya que el origen del ataque es exclusivamente lógico y se encuentra en fallos relacionados con el SDLC, la segmentación de red y la gestión de credenciales.

Por ejemplo, el fallo de SDLC se observa cuando una aplicación web se publica con vulnerabilidades como XSS descritas en OWASP, equivalente a dejar una puerta abierta en una aplicación accesible desde Internet.

La falta de segmentación de red permite que, una vez comprometido el sistema de soporte, el atacante alcance bases de datos críticas. Es comparable a un edificio donde todas las salas pueden abrirse sin restricciones. Una arquitectura Zero Trust evitaría este comportamiento.

La mala gestión de credenciales se produce al almacenar contraseñas en texto plano, situación equivalente a dejar una llave maestra visible y accesible para cualquier persona.

Por tanto, la respuesta adecuada consiste en realizar una auditoría integral de ciberseguridad basada en:

- OWASP.
- Zero Trust.
- DevSecOps.
- PCI-DSS.

La seguridad física únicamente tendría un papel complementario dentro de una estrategia global de protección.

Fin del informe